

Plan de réponse à un incident de compromission d'un serveur

TP Réponse aux incidents - Scénario Atlas Distribution

Nom(s) et prénom(s) du groupe	Groupe n°	Date
Anouar Mohamed - Zakaria Bouzouba	2	1er octobre 2026

Plan : 1 Fiche incident - 2 Rôles et RACI - 3 Sévérité et escalade - 4 Playbook technique - 5 Communication - 6 Restauration et continuité - 7 Retour d'expérience - 8 Main courante.

1. Fiche incident (Partie 1)

Champ	Contenu
Identifiant et date de détection	INC-ATLAS-001 - détecté le vendredi à 23h40 (EDR), qualifié le samedi à 00h15
Source de détection	EDR (23h40), SIEM (23h47), contrôle du trafic sortant (00h10), analyste d'astreinte (00h15)
Systèmes concernés	Confirmé : SRV-WEB-01, compte svc-backup. À vérifier : SRV-DB-01, NAS-BKP, annuaire
Données potentiellement touchées	Base clients : environ 40 000 comptes (nom, adresse, e-mail, mot de passe haché) ; sauvegardes. Aucune exfiltration confirmée à ce stade
Indicateurs de compromission	1) Connexion SSH réussie de svc-backup depuis une IP externe jamais vue (23h47). 2) Script inhabituel dans le dossier de dépôt de fichiers (23h55). 3) Trafic sortant environ 10 fois supérieur à la normale (00h10). 4) Processus inconnu lancé par le compte du serveur web (23h40)
Hypothèses	H1 : fichier malveillant (webshell) déposé via le dépôt de fichiers, exécuté par le compte web, puis vol des identifiants de svc-backup. H2 : identifiants de svc-backup déjà volés, connexion SSH directe. H3 : faille Apache/PHP exploitée à distance
Sévérité proposée	P1 - Critique : actif critique exposé sur Internet, compte de service lié aux sauvegardes, exfiltration possible de données personnelles

Q1 - Événement, incident ou crise ? C'est un **incident de sécurité**. Plusieurs signaux indépendants (EDR, SIEM, fichier, flux) se recoupent en 35 minutes et montrent un accès non autorisé : on dépasse le simple événement. Ce n'est pas encore une crise : aucune donnée volée ni arrêt du site n'est confirmé. Cela devient une crise si l'exfiltration est confirmée, si le site tombe, si SRV-DB-01 ou les sauvegardes sont touchés, ou si la presse s'en saisit.

Q2 - IOC les plus fiables, du plus au moins fiable :

- **Connexion SSH de svc-backup depuis une IP externe inconnue** : authentification réussie qui n'a pas lieu d'être, très peu de faux positifs.
- **Script inhabituel dans le dossier de dépôt** : artefact concret et analysable (probable webshell).
- **Trafic sortant x10** : fiable mais peut avoir une cause bénigne (promotion, pic de visites) ; à croiser avec la destination.
- **Processus inconnu signalé par l'EDR** : alerte automatique, à confirmer (faux positifs possibles), mais cohérente avec le reste.

Q3 - Vecteur et étendue. Vecteur le plus probable : H1 (le fichier et le processus précèdent la connexion SSH, qui serait la suite de l'intrusion). Étendue à vérifier :

- SRV-DB-01 : les identifiants de la base se trouvent souvent dans la configuration PHP du site (risque pour 40 000 comptes) ;
- NAS-BKP : svc-backup l'utilise, donc les sauvegardes peuvent être lues, supprimées ou chiffrées ;
- annuaire et autres serveurs où svc-backup est valide ; clés SSH et secrets stockés sur SRV-WEB-01 ;
- date de début inconnue : l'attaquant peut être là depuis plusieurs jours.

Q4 - Informations manquantes et moyen de les obtenir :

Information manquante	Comment l'obtenir rapidement
Heure de dépôt et contenu du script	Date du fichier, logs d'accès Apache, analyse sans exécution (hash, lecture)
Destination et volume du trafic sortant	Logs pare-feu / NetFlow, SIEM
Commandes lancées par l'attaquant	Chronologie EDR, auth.log, historique des commandes
Autres connexions de svc-backup	SIEM et annuaire : recherche par compte et par IP source

Information manquante	Comment l'obtenir rapidement
Accès à SRV-DB-01 et NAS-BKP	Logs de la base, logs du NAS, consultation depuis la console SIEM / EDR (lecture seule)
Première trace de l'intrusion	Remonter les logs jusqu'au dernier état propre (sert au choix de la sauvegarde)

2. Rôles et matrice RACI (Partie 2)

2.1 Rôles et contacts (noms fictifs). La nuit, tant que l'Incident Manager n'est pas joint, l'analyste tient la main courante.

Rôle	Titulaire	Suppléant	Missions principales	Contact la nuit
Incident Manager	Léa Martin	Hugo Bernard	Anime la cellule, arbitre, tient la main courante, décide du niveau	Téléphone d'astreinte (appel, relance à 10 min, puis suppléant)
Analyste SOC	Nour Haddad	Paul Girard	Analyse, corrélation, preuves, surveillance des autres systèmes	Sur place / astreinte SOC
Administrateur système	Yanis Roux	Sara Lopez	Isolement, révocation, collecte technique, éradication, restauration	Téléphone d'astreinte (appel + SMS)
Juridique / DPO	Claire Dupont	Marc Petit	Obligations RGPD, notification, contrats, preuves	Appel direct, joignable sous 1 h
Communication	Julie Faure	Tom Richard	Messages internes et externes, porte-parole	Appel direct, joignable sous 2 h
Direction / RSSI	Éric Lambert (RSSI), Anne Perrin (DSI)	DG : Paul Morel	Décisions majeures, arbitrage métier, validation de la remise en production	Astreinte téléphonique (RSSI et DSI), appel direct

2.2 Matrice RACI (un seul A par ligne).

Activité	Incident Mgr	SOC	Admin	Juridique	Comm.	Direction
Qualifier l'incident	A	R	C	I	I	I
Isoler le serveur	A	C	R	I	I	I
Collecter les preuves	A	R	R	C	-	I
Révoquer les comptes et secrets	A	C	R	I	-	I
Notifier les autorités	C	I	I	R	C	A
Communiquer aux clients	C	I	I	C	R	A
Décider la remise en production	R	C	R	I	I	A

3. Sévérité et escalade (Partie 2)

Niveau	Critères	Escalade vers	Délai
P4 Mineur	Événement isolé, aucun impact, aucun actif critique	Analyste SOC	Jour ouvré suivant (24 h)
P3 Modéré	Compromission d'un système non critique, impact limité, pas de données sensibles	Incident Manager	4 h
P2 Majeur	Compromission avérée d'un système important ou risque sur des données	Incident Manager + RSSI	1 h
P1 Critique	Actif critique compromis, exfiltration possible ou avérée de données personnelles, arrêt ou risque d'arrêt du site	Incident Manager, RSSI, DSI, Direction, DPO	30 min (appel téléphonique)

Q5 - Niveau à 00h15 : P1. Justification : SRV-WEB-01 est critique et exposé, le compte svc-backup touche les sauvegardes, le trafic sortant évoque une exfiltration possible de 40 000 comptes, et personne ne connaît l'étendue.

Réévaluation toutes les heures et à chaque nouveau fait : baisse à P2 si l'analyse montre un périmètre limité à SRV-WEB-01 sans accès aux données ; passage en gestion de crise si exfiltration confirmée, site à l'arrêt, SRV-DB-01 ou NAS-BKP touchés.

Q6 - Qui prévenir en premier ? L'Incident Manager / RSSI d'astreinte, **par appel téléphonique** (pas par e-mail, qui peut être compromis), à 00h20 et au plus tard à 00h30 (délai P1). Ensuite : DSI à 00h30, DPO / Juridique et Direction au plus tard à 01h30, car l'horloge des 72 h du RGPD démarre à la connaissance de la violation.

4. Playbook technique (Partie 3)

Points de décision

- **Isoler ou observer ?** Isoler tout de suite, après une capture volatile de quelques minutes. Risque d'isoler : alerter l'attaquant et perdre l'observation. Risque d'observer : exfiltration qui continue et rebond vers SRV-DB-01 et NAS-BKP. Le trafic sortant x10 tranche pour l'isolement.
- **Éteindre ou laisser allumé ?** Laisser allumé, *isolé du réseau*, jusqu'à la capture de la mémoire et du disque. Éteindre fait perdre la mémoire (processus, connexions, clés). On n'éteint que si un chiffrement ou une destruction est en cours.
- **Révoquer** : svc-backup (désactivation immédiate puis nouveau secret), clés SSH autorisées, mot de passe de la base, secrets applicatifs, sessions web. Le serveur est reconstruit, ses secrets sont considérés comme compromis.
- **Vérifier SRV-DB-01 et NAS-BKP sans alerter** : consulter les logs depuis la console SIEM / EDR en lecture seule, depuis un poste d'administration sain, avec un compte distinct de svc-backup. Pas de connexion interactive tant que le périmètre est inconnu.
- **Ordre de collecte** (du plus volatil au moins volatil) : mémoire, connexions et processus, logs, image du disque, fichier suspect. Intégrité : empreinte SHA-256, copie en lecture seule, chaîne de traçabilité, heures synchronisées.

Phase	N°	Action précise	Responsable	Outil	Trace à conserver
Détecter et qualifier	1	00h15 Prendre en charge les alertes, corrélérer EDR, SIEM et flux, ouvrir la fiche incident et la main courante	SOC	SIEM, EDR	Fiche INC, main courante
	2	00h20 Appeler l'Incident Manager et le RSSI, proposer P1	SOC	Téléphone d'astreinte	Heure d'appel et décision de niveau
	3	Relever l'IP source du SSH et l'IP de destination du trafic, calculer l'empreinte du script (sans l'exécuter)	SOC	SIEM, pare-feu, sha256sum	Export des requêtes, empreinte
Contenir	4	Capturer l'état volatil : connexions et processus de SRV-WEB-01 (lecture seule)	Admin	EDR live, ss, ps	Sortie hachée, heure
	5	Isoler SRV-WEB-01 (quarantaine EDR et règle pare-feu) sans l'éteindre	Admin	EDR, pare-feu	Règle appliquée, heure
	6	Désactiver svc-backup, bloquer l'IP source du SSH et l'IP de destination, retirer les clés SSH douteuses	Admin	Annuaire, pare-feu	Journal des changements
	7	Suspendre la sauvegarde de 02h00 et protéger les sauvegardes existantes (rétention 30 jours)	Admin	Planificateur, NAS-BKP	Capture d'écran, décision
	8	Surveiller SRV-DB-01 et NAS-BKP en lecture seule ; activer la page de maintenance si nécessaire	SOC / Admin	SIEM, WAF / DNS	Requêtes et résultats
Collecter les preuves	9	Capturer la mémoire de SRV-WEB-01	Admin	AVML / LiME	Fichier et SHA-256
	10	Snapshot ou image du disque et export des logs (auth, Apache, EDR, SIEM)	Admin / SOC	Snapshot VM, dd, rsync	Empreintes, chaîne de traçabilité
	11	Archiver le script suspect dans un conteneur chiffré, hors serveur	SOC	Archive chiffrée	Empreinte, lieu de stockage
Éradiquer	12	Chercher les persistances (cron, clés SSH, comptes, services, webshells) et confirmer le vecteur dans les logs Apache	SOC	EDR, grep, YARA	Rapport d'analyse
	13	Corriger la faille : interdire l'exécution dans le dossier de dépôt, filtrer les types de fichiers, appliquer les correctifs	Admin	Configuration Apache/PHP, gestionnaire de paquets	Demande de changement
	14	Renouveler tous les secrets : svc-backup, clés SSH, mot de passe de la base, secrets applicatifs	Admin	Coffre de secrets	Journal de rotation
	15	Reconstruire SRV-WEB-01 à partir d'une image saine (pas de nettoyage à la main)	Admin	Image / scripts de déploiement	Version de l'image, heure

Phase	N°	Action précise	Responsable	Outil	Trace à conserver
Restaurer et vérifier	16	Choisir le point de restauration (avant la première trace) et contrôler l'intégrité de la sauvegarde	Admin / SOC	NAS-BKP, antimalware	Résultat des contrôles
	17	Restaurer en environnement isolé, tester, scanner (IOC, vulnérabilités)	SOC / Admin	EDR, scanner de vulnérabilités	Rapport de tests
	18	Remise en production par paliers après décision go / no-go, surveillance renforcée 7 jours	Incident Manager	SIEM, EDR	Décision signée, heure

Q7 - Erreurs possibles d'une équipe pressée et parade du playbook :

Erreur	Parade
Éteindre ou redémarrer trop tôt (perte de la mémoire)	Isoler sans éteindre ; capture avant toute coupure (actions 4 à 5, 9)
Supprimer le script ou « nettoyer » à la main (preuves détruites, persistance oubliée)	Collecte avant éradication ; reconstruction depuis une image saine (actions 9 à 11, 15)
Se connecter avec svc-backup ou depuis un poste non sûr	Poste et comptes d'administration distincts, lecture seule (point de décision 4)
Ne traiter que le serveur et oublier le compte, les clés, la base, le NAS	Révocation de tous les secrets, surveillance de SRV-DB-01 et NAS-BKP (actions 6 à 8, 14)
Laisser la sauvegarde de 02h00 tourner et écraser des sauvegardes saines	Suspension et protection des sauvegardes (action 7)
Restaurer sur un serveur non corrigé ou depuis une sauvegarde infectée	Correction avant restauration, contrôle d'intégrité, tests isolés (actions 13, 16 à 17)
Ne rien consigner ou écrire par e-mail compromis	Main courante datée, canal hors bande

5. Communication de crise (Partie 4)

5.1 Publics et messages. Une seule voix officielle, des faits vérifiés, pas de spéculation.

Public	Message clé	Canal	Responsable	Délai
Direction et comité de crise	Incident P1 sur SRV-WEB-01, données clients possiblement touchées, décisions attendues (maintenance, notification)	Appel puis visio / canal hors bande	Incident Manager	30 min après la décision P1
Équipes internes	Un incident est en cours, consignes à suivre, qui contacter	Canal hors bande, puis messagerie une fois sûre	Communication, validé par l'Incident Manager	2 h
Clients	Faits confirmés, mesures prises, gestes à faire (changer le mot de passe), prochain point	E-mail et bannière sur le site	Communication, validé par Direction et Juridique	Dès confirmation d'une violation, visé sous 48 h
Presse et réseaux sociaux	Déclaration courte et factuelle, un porte-parole unique, renvoi vers la page d'information	Communiqué, compte officiel	Direction (porte-parole), Communication	Prête sous 4 h, publiée si sollicitation ou fuite
Autorité de protection des données	Nature de la violation, volume, conséquences, mesures	Téléservice de l'autorité	Juridique / DPO (Direction approuve)	72 h maximum après connaissance

5.2 Rédaction

Message interne

Objet : Incident de sécurité en cours - consignes.

Un incident de sécurité touche le serveur du site marchand. La cellule de crise est active. **À faire** : signaler toute anomalie à l'astreinte (n° d'astreinte), n'échanger sur l'incident que sur le canal indiqué. **À ne pas faire** : ne pas redémarrer, supprimer ni « nettoyer » un serveur, ne pas parler à la presse ni sur les réseaux sociaux, ne pas transférer ce message. **Contact** : Incident Manager (astreinte). Prochain point d'information : samedi à 08h00.

Message aux clients

Objet : Information importante concernant votre compte Atlas Distribution.

Dans la nuit du vendredi au samedi, nous avons détecté un accès non autorisé à l'un de nos serveurs. **Ce qui est confirmé** : l'accès non autorisé. Nous ne pouvons pas encore dire si vos informations (nom, adresse, e-mail, mot de passe protégé) ont été

consultées. **Ce que nous faisons** : le serveur est isolé, les accès sont révoqués, une enquête est en cours et nous informons les autorités compétentes. **Ce que vous devez faire** : par précaution, changez votre mot de passe (et celui de tout autre service où vous l'utilisez) et méfiez-vous des e-mails ou SMS inattendus. Nous ne vous demanderons jamais votre mot de passe. **Prochain point d'information** : samedi à 18h00 par e-mail et sur notre site.

Q8 - Obligations de notification (RGPD). Si les données des 40 000 clients sont exfiltrées, il s'agit d'une violation de données personnelles. Atlas est responsable de traitement de ces données.

- **Autorité** : l'autorité de protection des données du pays de l'établissement (la CNIL si l'entreprise est en France).
- **Délai** : 72 h après la connaissance de la violation. Si tout n'est pas connu, notification initiale puis compléments. Noter l'heure de connaissance dans la main courante. La règle est à vérifier selon le pays de l'entreprise.
- **Contenu** : nature de la violation, catégories et nombre approximatif de personnes (environ 40 000) et de données, contact du DPO, conséquences probables, mesures prises ou prévues.
- **Personnes concernées** : à informer sans retard injustifié si le risque est élevé (e-mail, adresse, mot de passe haché : hameçonnage et réutilisation de mot de passe).
- **Registre des violations** : à compléter même si aucune notification n'était requise.
- **Qui** : le Juridique / DPO prépare et dépose, la Direction approuve.

6. Restauration et continuité (Partie 5)

Q9 - Point de restauration. La sauvegarde de 02h00 n'a pas encore tourné : la dernière est celle de vendredi 02h00, conservées 30 jours, plus la copie hors ligne du dimanche.

- Retrouver la **première trace** de l'intrusion (premier SSH externe, premier dépôt de fichier, premier trafic anormal) dans les logs, en remontant jusqu'au dernier état propre.
- Choisir la sauvegarde **la plus récente antérieure** à cette date, dans la limite du RPO de 24 h, puis la tester en environnement isolé (antimalware, recherche d'IOC, comparaison du code avec la version de référence).
- Pour la base : restaurer le point sain puis rejouer les transactions légitimes (journaux de la base, paiements, e-mails de commande).
- **Si les sauvegardes récentes sont douteuses** (svc-backup avait accès au NAS) : remonter dans le temps jusqu'à 30 jours, utiliser la copie hors ligne du dimanche, reconstruire le code depuis les sources. Si le RPO de 24 h est dépassé, la Direction arbitre et la perte est reconstituée autant que possible.

Q10 - Tenir le RTO de 8 h (à partir de la mise à l'arrêt du site) :

Étape	Contenu
0 à 1 h	Qualification, isolement, révocation, collecte ; préparation parallèle d'un nouveau serveur
1 à 3 h	Reconstruction depuis une image saine ; identification du point de restauration en parallèle de l'analyse
3 à 6 h	Restauration des données, correction de la faille, durcissement, renouvellement des secrets
6 à 8 h	Tests, contrôles (Q11), décision go / no-go, remise en production par paliers

- Gagner du temps : travailler en parallèle (analyse sur l'image, reconstruction sur un nouveau serveur), automatiser le déploiement, rappeler les suppléants.
- **Mode dégradé pour les clients** : page de maintenance avec statut et heure de reprise, catalogue en lecture seule, connexion aux comptes désactivée jusqu'au changement de mot de passe, prise de commande par téléphone ou e-mail pour les clients prioritaires, traitement différé des commandes ensuite.

Q11 - Contrôles avant remise en production de SRV-WEB-01 :

- aucun IOC (scan EDR, empreintes, IP, comptes, clés, tâches planifiées) ;
- faille corrigée et testée (exécution impossible dans le dossier de dépôt), correctifs système, Apache et PHP appliqués ;
- tous les secrets renouvelés, aucun ancien en usage ; SSH limité (clés, pas de compte de service ouvert depuis Internet, accès par bastion ou VPN) ;
- journalisation et EDR actifs et remontant au SIEM ; scan de vulnérabilités sans point critique ;
- intégrité des données (comptages, cohérence) et parcours d'achat testé ; SRV-DB-01 et NAS-BKP confirmés sains ;
- validation go / no-go par l'Incident Manager, le RSSI et la Direction ; surveillance renforcée pendant 7 jours.

7. Retour d'expérience

Constat	Action d'amélioration	Responsable	Échéance
Compte de service accessible en SSH depuis Internet, sans second facteur	Accès SSH par bastion ou VPN, liste d'IP autorisées, clés, droits minimaux, rotation des secrets	Admin système	J+14
Dépôt de fichiers pouvant exécuter du code	Interdire l'exécution, filtrer les types, scanner les fichiers déposés	Admin système / développeurs	J+14
35 minutes entre la première alerte et la prise en compte	Corrélation automatique, alerte SMS à l'astreinte, règle « SSH externe d'un compte de service »	SOC	J+30
Un seul analyste la nuit	Astreinte renforcée, procédures claires, suppléants formés	DSI	J+30
Sauvegardes accessibles par le compte compromis	Sauvegardes immuables ou hors ligne plus fréquentes, test de restauration régulier	Admin système	J+45
Plan de réponse jamais éprouvé	Exercice de crise semestriel, modèle de notification RGPD prêt	Incident Manager / DPO	J+60

8. Main courante (modèle prérempli)

Heures de la nuit du scénario (faits) et heures cibles du plan (actions), à compléter avec les heures réelles.

Heure	Fait ou action	Auteur	Décision / suite
Ven 23h40	Alerte EDR : processus inconnu sur SRV-WEB-01	EDR	-
Ven 23h47	SIEM : SSH réussi de svc-backup depuis une IP externe inconnue	SIEM	-
Ven 23h55	Script inhabituel dans le dossier de dépôt	-	-
Sam 00h10	Trafic sortant environ 10 fois supérieur à la normale	-	-
Sam 00h15	Alertes reçues par l'analyste ; ouverture de INC-ATLAS-001 et de la main courante	Analyste SOC	Corrélation des alertes
Sam 00h20	Appel à l'Incident Manager / RSSI	Analyste SOC	P1 proposé
Sam 00h30	Incident Manager joint ; P1 confirmé ; DSI prévenu	Incident Manager	Décision d'isoler
Sam 00h45	Capture volatile, isolement de SRV-WEB-01, svc-backup désactivé, IP bloquées	Administrateur	Suivi dans la main courante
Sam 01h00	Sauvegarde de 02h00 suspendue ; page de maintenance si besoin	Administrateur	Sauvegardes protégées
Sam 01h30	DPO / Juridique et Direction informés	Incident Manager	Heure de connaissance à fixer
Sam 02h00	Capture mémoire, image disque, export des logs	Admin / SOC	Hachage des preuves
...	...	...	...